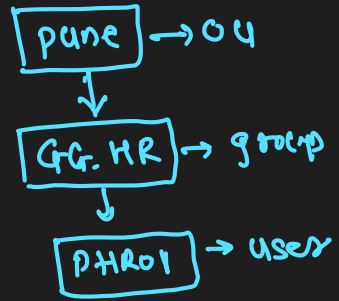
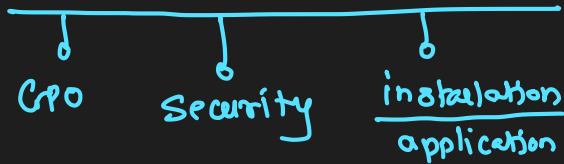




Group Policies

used to add restrictions on objects
(users/groups/computers)

Hardening operating system

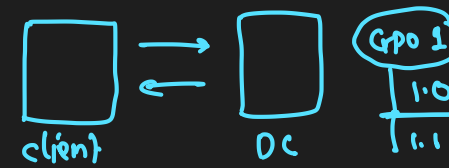


Introduction



- Group Policy is the built-in mechanism in Active Directory Domain Services (AD DS) for centrally configuring and enforcing settings on domain-joined Windows computers and the users who log on to them
→ restrictions
- One administrator can change a setting once and have it applied to thousands of machines automatically
- **Group Policy controls**
 - **Security:** password rules, account lockout, user rights, audit, firewall, BitLocker, Credential Guard, LAPS
 - **Desktop and user experience:** Start menu, Control Panel access, wallpaper, drive maps, printers, shortcuts
 - **Software:** application install (MSI), AppLocker / App Control for Business (WDAC), Windows Update for Business settings
→ WSUS server
 - **Scripts:** startup/shutdown (computer) and logon/logoff (user) scripts
 - **Data:** folder redirection, offline files, roaming profile behaviour
- **Importance of Group Policies**
 - **Consistency:** every machine in an OU gets the same baseline, which removes configuration drift
 - **Security hardening:** CIS / Microsoft Security Baselines are delivered as GPOs
 - **Delegation:** OU-level GPOs let junior admins manage their own scope without Domain Admin rights
 - **Auditability:** GPMC reports show exactly which settings apply and wheres

Core concepts



- A Group Policy Object (GPO) is a named **container of settings**
- It does nothing until it is **linked to a site, domain or OU**; **one GPO can be linked to many places, and one container can have many GPOs linked**
- **The two halves of every GPO**
 - **Group Policy Container (GPC)**

CN = Policies, CN=System, DC=Sunbeam, DC=local

 - **Stored in:** AD database: CN={GUID}, CN=Policies, CN=System, DC=domain, DC=com
 - **Contains:** Version number, status, WMI filter link, CSE GUIDs, permissions
 - **Group Policy Template (GPT)**
 - **Stored in:** SYSVOL \ \domain \ SYSVOL \ domain \ Policies \ {GUID}
 - **Contains:** GPT.INI, Machine \ and User \ folders, Registry.pol, scripts, security template GptTmpl.inf, Preferences XML
- **The GUID links the two halves**
- **If the GPC and GPT version numbers differ on a DC (replication lag), clients may skip or partially apply the GPO**

Types of GPOs



■ **Local GPOs** → client | computers

- Local GPOs apply only to the specific computer on which they reside and the users who log on to that computer
- Every Windows computer has one built-in local GPO, which is managed locally using the Local Group Policy Editor
- In an Active Directory environment, local GPOs are the least influential and have the lowest precedence in processing order (Local > Site > Domain > OU)

■ **Non-local (Domain-based) GPOs**

- Non-local GPOs are the primary mechanism for Group Policy in a domain environment
- They are stored in Active Directory and replicate to all domain controllers
- These GPOs do not take effect until they are linked to an Active Directory container, such as a site, domain, or organizational unit (OU)
- You can link a single GPO to multiple containers, and a single container can have multiple GPOs linked to it

■ **Starter GPOs**

- Starter GPOs are templates that contain a pre-configured set of policy settings, acting as a baseline for creating new policies
- They are designed to save administrators time by providing a standardized starting point for common configurations

Default GPOs ◉ created by active directory



■ Default Domain Policy

- Linked to The domain itself
- Applies to all users and computers in the domain.
- It is pre-configured with critical Password Policy, Account Lockout Policy, and Kerberos Policy settings
- Microsoft strongly recommends not adding unrelated settings here

■ Default Domain Controllers Policy

- The Domain Controllers OU
- Applies only to domain controllers (or other objects placed in that OU)
- It is used to manage Audit Policy and User Rights Assignment specifically for your DCs

■ Key Points

- Precedence: The Default Domain Policy has the highest precedence among all GPOs linked to the domain
- Best Practice: Keep the Default Domain Policy reserved for its core account policies. Create separate, additional GPOs for any other settings you need to apply broadly across the domain
- Don't Move DCs: Moving a domain controller out of the Domain Controllers OU will stop the Default Domain Controllers Policy from applying, which can cause inconsistent behavior



Processing order (LSDOU)

- It determines which settings win when multiple GPOs configure the same setting
- Settings are processed in this order, from lowest to highest precedence
- **Local**
 - **Scope:** The computer itself
 - The built-in local GPO
 - Lowest precedence; easily overridden
- **Site**
 - **Scope:** Active Directory site
 - GPOs linked to the site object. Rarely used, but useful for site-specific settings (e.g., regional printers)
- **Domain**
 - **Scope:** The entire domain
 - GPOs linked to the domain root, including the Default Domain Policy
- **OU**
 - **Scope:** Organizational Units
 - GPOs linked to OUs, processed from the parent OU down to the child OU. The deepest, most specific OU has the highest precedence

Configuration – Computer Configuration



- **Computer Configuration** contains settings that apply to the **computer itself, regardless of who logs on**
- These settings are processed when the **operating system starts, during background refresh, and roughly every 90–120 minutes thereafter**
- **What lives here**
 - **Software Settings:** Software installation packages assigned to the computer (installs at startup)
 - **Windows Settings:** Security settings (password policy, audit policy, user rights), scripts (startup/shutdown), and network configuration
 - **Administrative Templates:** Registry-based policies that govern system behavior, such as disabling USB storage or restricting Control Panel access
- **Practical example:** If you enable "Deny access to Control Panel" under Computer Configuration, no user who logs on to that machine can access it, even administrators

Configuration - User Configuration



- **User Configuration** contains settings that apply to the **user account**, **regardless of which computer they log on to**
- These settings are processed **at user logon** and **during background refresh**.
- **What lives here**
 - **Software Settings:** Software assigned or published to users
 - **Windows Settings:** Folder Redirection (Desktop, Documents to network shares), logon/logoff scripts, and Internet Explorer maintenance
 - **Administrative Templates:** Policies that shape the user's environment, such as Start menu layout, desktop restrictions, and mapped drives
- **Practical example:** If you enable "Hide Internet Explorer icon on desktop" under User Configuration, that user will not see the icon on any computer they log on to



Processing behaviour and refresh

- Computer policy applies at startup and user policy at logon (foreground); both then refresh in the background every 90 minutes with a random offset of 0–30 minutes
- Domain controllers refresh every 5 minutes
- **Foreground**
 - Computer startup, user logon
 - Software Installation, Folder Redirection, some Drive Maps
 - Asynchronous (Fast Logon Optimization)
- **Background**
 - Periodic refresh, gpupdate
 - Asynchronous
- **Forcing an update** → must be executed on the machine on which the policy need to be applied
 - gpupdate: Applies changed policy (computer + user)
 - gpupdate /force: Re-applies all settings, changed or not
 - gpupdate /target: computer Computer settings only
 - gpupdate /force /boot or /logoff: Reboots/logs off if a foreground-only setting needs it

↪ logoff and login



Common Tasks

Password Policy



- It defines password complexity, lifetime, and history requirements for all user accounts in the domain
- It is a foundational component of your Active Directory security baseline
- **Password Policy is found under**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Password Policy
- **Critical Scope Rule**
 - Only a GPO linked at the **domain root level** (typically the **Default Domain Policy**) can enforce password settings on **domain user accounts**
 - If you configure Password Policy in an OU-linked GPO, it will only affect the **local accounts** on computers within that OU, not domain users

Password Policy - Core Settings



Setting	Purpose	Recommended
<u>Enforce password history</u>	Prevents users from reusing recent passwords. Stores a specified number of previous passwords.	24 (maximum)
<u>Maximum password age</u>	Number of days before a password expires and must be changed.	60–90 days
<u>Minimum password age</u>	Number of days a user must wait before changing a password again. Prevents bypassing history by rapidly cycling passwords.	1 day
Minimum password length	Minimum number of characters required.	8–14 characters
Password must meet complexity requirements	Requires at least three of four character categories: uppercase, lowercase, digits, special characters.	Enabled
Store passwords using reversible encryption	Stores passwords in a reversible format. Only needed for specific legacy authentication scenarios.	Disabled
Minimum password length audit	(Windows Server 2016+) Logs events when passwords shorter than a target length are set, allowing you to measure impact before enforcing a stricter length.	Use as needed

Fine-Grained Password Policies (FGPP)



- Fine-Grained Password Policies (FGPP) allow you to apply stricter password requirements to specific users or groups, such as Domain Admins, without affecting standard user accounts
- **Step 1: Open ADAC and Navigate to the Container**
 - Open Active Directory Administrative Center
 - In the left navigation pane, expand your domain, open the **System** container, and select **Password Settings Container**
- **Step 2: Create the Password Settings Object (PSO)**
 - In the **Tasks** pane, click **New** and select **Password Settings**
 - **Name:** Enter a descriptive name (e.g., Domain Admin Password Policy)
 - **Precedence:** Enter a number (e.g., 1). Lower numbers mean higher priority
 - **Settings:** Configure the desired password length, history, and complexity. For privileged accounts, a minimum length of 16 or 25 characters is recommended
- **Step 3: Apply the Policy to a Group**
 - Under **Directly Applies To**, click **Add**
 - Type the name of the **Global Security Group** (e.g., Domain Admins), click **Check Names** to validate, and click **OK** . Click **OK** again to commit the creation



Account Lockout Policy

- **Account Lockout Policy** mitigates brute-force password-guessing attacks by disabling a user account after a defined number of failed sign-in attempts
- **Account Lockout Policy is found under**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Account Lockout Policy
- **Critical Scope Rule**
 - For domain accounts, this policy must be configured in a GPO linked at the **domain root level** (typically the **Default Domain Policy**)
 - If configured in an OU-linked GPO, it applies only to the **local SAM accounts** of computers in that OU, not domain users

Setting	Purpose	Recommended
Account lockout threshold	Number of failed sign-in attempts that triggers a lockout. Setting to 0 disables lockout entirely	5–10 attempts
Account lockout duration	Minutes the account remains locked. Setting to 0 requires an administrator to manually unlock	15–30 minutes
Reset account lockout counter after	Minutes of no failed attempts before the failure count resets to zero	15–30 minutes
Allow Administrator account lockout	Extends lockout to the built-in Administrator account for network sign-ins. Enabled by default on current installations	Enabled

Kerberos Policy



- **Kerberos Policy** controls ticket lifetimes and clock synchronization tolerance for the Kerberos V5 authentication protocol in a domain environment
- It is part of the Active Directory default security baseline and typically **does not need to be modified**, as the default values balance security and usability
- **Kerberos Policy is located at**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Account Policies > Kerberos Policy
- **Critical Scope Rule**
 - Like Password Policy and Account Lockout Policy, Kerberos Policy **must be linked at the domain root level** (typically the **Default Domain Policy**) to affect domain user accounts.
 - It can only be set on **domain controllers**

Audit Policy



- **Audit Policy** turns security policy into visibility
- Without it, you cannot tell who changed a privileged group, who accessed a sensitive share, or which account is being brute-forced
- **Audit Policy is found under**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Advanced Audit Policy Configuration
- **Critical Scope Rule**
 - Use **Advanced Audit Policy Configuration** (61 subcategories) instead of the legacy **Basic Audit Policy** (9 broad categories)
 - Enable the security option "**Audit: Force audit policy subcategory settings (Windows Vista or later)**" to make advanced settings authoritative. Without this option, results are unpredictable

Administrator Account



- Disabling or renaming the built-in Administrator account is a common hardening step
- For the local built-in Administrator on domain-joined workstations and member servers, the recommendation is different: **disable and rename it**
- **Disable**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Accounts: Administrator account status → Set to Disabled.
- **Rename**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > Security Options > Accounts: Rename administrator account → Enter a name that does not suggest administrative access
- **Create and edit a new GPO**
 - Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > User Rights Assignment
 - Deny access to this computer from the network
 - Deny log on as a batch job
 - Deny log on as a service
 - Deny log on through Remote Desktop Services



Removable Storage Restrictions

- Removable Storage / USB Restrictions in Group Policy allow you to block unauthorized USB drives to prevent data exfiltration and malware introduction
- **Create and edit a new GPO**
 - Computer Configuration > Policies > Administrative Templates > System > Removable Storage Access
- **Enable the following policies**
 - All Removable Storage classes: Deny all access
 - Removable Disks: Deny read access
 - Removable Disks: Deny write access
 - Removable Disks: Deny execute access

Control Panel Restrictions



- Control Panel Restrictions in Group Policy allow you to block access to the Control Panel and Windows Settings entirely, or hide only specific items you do not want users to access
- Because these are User Configuration policies, they apply to the user account regardless of which computer they sign in to
- **Create and edit a GPO**
 - User Configuration > Policies > Administrative Templates > Control Panel
- **Option 1: Block Everything**
 - It prevents users from launching the Control Panel and the modern Settings app
 - Policy to Configure: "Prohibit access to Control Panel and PC settings"
 - Prevents Control.exe and SystemSettings.exe from starting .
 - Removes the Control Panel from the Start screen and File Explorer .
 - If a user tries to open a Control Panel item from a context menu, an error message appears explaining that a setting prevents the action .
 - An error appears when clicking the Settings icon in the Start menu
 - **Limitation:** Users can still access configuration tools using Run, CMD, or Control.exe directly. To fully enforce this restriction, you need to combine it with **AppLocker** or **Software Restriction Policies**

Control Panel Restrictions



■ Option 2: Hide Specific Control Panel Items

- Policy to Configure: "Hide specified Control Panel items"
- Network and Sharing Center: Microsoft.NetworkAndSharingCenter
- Windows Update: Microsoft.WindowsUpdate
- User Accounts: Microsoft.UserAccounts
- Programs and Features: Microsoft.ProgramsAndFeatures
- Windows Defender Firewall: Microsoft.WindowsDefender
- Device Manager: Microsoft.DeviceManager
- System: Microsoft.System
- Administrative Tools: Microsoft.AdministrativeTools

↳ Canonical Name

Desktop Restrictions



- Desktop Restrictions in Group Policy allow you to control what users see on their desktop and prevent them from making unwanted changes
- These are **User Configuration** policies, so they follow the user account regardless of which computer they sign in to
- **Create and edit a GPO**
 - User Configuration > Policies > Administrative Templates > Desktop
- **Policy to configure**
 - Hide and disable all items on the desktop
 - Remove Recycle Bin icon from desktop
 - Remove Computer icon on the desktop
 - Hide Internet Explorer icon on desktop
 - Remove Properties from the Recycle Bin context menu
 - Remove Properties from the Computer icon context menu
 - Remove Desktop Cleanup Wizard